REVUE DE PRESSE HEBDOMADAIRE

Software Compliance

L'essentiel de la conformité des logiciels embarqués dans les produits de défense

N° 5 – Mardi 3 novembre 2026

Revue de presse hebdomadaire, tous les mardis

Une faille critique de Brotli, bibliothèque de compression enfouie dans de nombreux logiciels, est activement exploitée ; une faille du noyau Linux rejoint le même catalogue de la CISA et une extension d'outil de développement a été piégée ; la règle des affiliés du BIS doit revenir le 10 novembre ; l'OFAC sanctionne des livraisons de logiciels à un fabricant de missiles russe.

DANS CE NUMÉRO

SBOM et normes 1
Outils 2
Chaîne d'approvisionnement 2
Commerce international 3
France et UE 3
Licences 4
Glossaire 4
Agenda 4

À LA UNE

Brotli, une faille exploitée dans un composant enfoui

Une faille critique de la bibliothèque de compression Brotli est activement exploitée ; souvent recopiée dans le code des logiciels, elle échappe aux inventaires fondés sur les paquets.

Brotli : le 27 octobre 2026, la CISA a inscrit dans son catalogue des vulnérabilités activement exploitées une faille critique du décodeur de cette bibliothèque de compression, qui peut permettre l'exécution de code à distance ; les versions 1.0.3 à 1.2 sont touchées.

Un attaquant distant non authentifié peut, avec un flux compressé malveillant, corrompre la mémoire du décodeur ou exécuter du code.

Le risque tient à la façon dont Brotli entre dans les logiciels. Selon JFrog, il arrive souvent par des dépendances transitives ou intégré dans des binaires natifs : des versions publiées peuvent rester vulnérables après la correction du code source.

Le fabricant doit chercher la bibliothèque dans ses binaires, pas seulement dans son SBOM : depuis le 11 septembre, une vulnérabilité activement exploitée d'un produit relevant du CRA se déclare à l'ENISA. Un produit qui décompresse des données reçues du réseau pourrait être exposé à distance et exiger une nouvelle version livrée aux clients.

EN BREF

Plateforme unique du CRA : lancée par l'ENISA le 11 septembre 2026, elle reçoit les déclarations des fabricants.

Périmètre : les déclarations CRA visent aussi les produits déjà sur le marché avant le 11 septembre et se poursuivent après la fin du support.

SBOM, NORMES ET RÉFÉRENTIELS

Une nouvelle autorité de numérotation CVE couvre les projets de la Linux Foundation ; l'ETSI publie une spécification contre les hypertrucages ; CycloneDX 2.0 et les normes du CRA restent attendus.

Akrites SIRT : une autorité CVE pour les projets de la Linux Foundation

Akrites SIRT : selon la lettre d'information de l'OpenSSF du 30 octobre 2026, cette équipe de réponse est désormais autorité de numérotation CVE pour les projets rattachés à la Linux Foundation ou à ses sous-fondations, sauf ceux qui ont leur propre autorité.

Le périmètre couvre aussi les sous-fondations de la Linux Foundation ; un projet qui dispose déjà de sa propre autorité de fournisseur garde la sienne. Une CNA attribue les identifiants CVE aux vulnérabilités de son périmètre et publie leurs fiches.

La même lettre signale un article primé sur la « Software Dark Matter » : des fichiers critiques pour la sécurité qui échappent aux déclarations SBOM habituelles.

La veille de vulnérabilités doit suivre les avis de cette nouvelle autorité pour les composants concernés.

ETSI TS 104 275 : mesures contre les hypertrucages produits par l'IA générative

ETSI TS 104 275 : publiée le 29 octobre 2026, cette spécification technique propose des mesures et des essais pour réduire le risque qu'un système d'IA générative produise des hypertrucages nuisibles ; elle se présente comme un soutien aux objectifs de l'AI Act.

Élaborée par le comité technique de l'ETSI sur la sécurisation de l'IA, la spécification vise aussi à renforcer la responsabilité des développeurs et des exploitants. Elle s'appuie sur les exigences de cybersécurité de base de la norme EN 304 223 pour les modèles et systèmes d'IA.

Parmi les garde-fous cités figurent le filtrage des contenus, le marquage des contenus générés par IA et l'avertissement des utilisateurs.

Le texte est volontaire : il ne crée aucune obligation.

EN BREF

CycloneDX 2.0 : version attendue à l'automne 2026, ratification par Ecma en décembre ; le format s'étendrait aux modèles de menaces et à la provenance des composants physiques.

Normes du CRA : la procédure d'approbation de 17 projets de normes verticales de l'ETSI se termine d'ici mi-novembre 2026 ; ces projets visent à devenir des normes harmonisées.

OUTILS ET SERVICES DE CONFORMITÉ

cdxgen repère les copies de Brotli dans les binaires ; Grype et Syft publient de nouvelles versions.

cdxgen 13.6 : repérer Brotli dans les binaires et les extensions d'éditeurs

cdxgen 13.6 : publiée le 31 octobre 2026, cette version du générateur de SBOM détecte les décodeurs Brotli intégrés aux environnements d'exécution et aux binaires, en lisant l'état du correctif dans le décodeur lui-même ; elle inventorie aussi les extensions des éditeurs de code.

Selon les notes de version, la plupart des copies du décodeur Brotli ne sont pas des paquets : un SBOM tiré des seuls gestionnaires de paquets ne les voit pas. L'outil répond ainsi directement à la faille CVE-2026-111497.

L'analyse des éditeurs de code lit désormais les emplacements où VS Code et ses dérivés installent réellement les extensions, sur chaque plateforme. La version identifie aussi l'interpréteur Ruby, pour rapprocher ses propres vulnérabilités.

Les équipes qui produisent des SBOM de binaires peuvent l'utiliser pour rechercher les copies vulnérables. L'inventaire des extensions pourrait aider à contrôler les postes qui construisent les logiciels livrés.

Grype 0.121.1 : correctifs pour OpenVEX et les SBOM CycloneDX

Grype 0.121.1 : publiée le 2 novembre 2026, cette version corrective du scanneur de vulnérabilités d'Anchore corrige le traitement des PURL sans version dans les documents OpenVEX et une allocation mémoire sans limite sur certains SBOM CycloneDX décrivant un modèle d'apprentissage automatique.

La correction OpenVEX porte sur une contrainte erronée appliquée aux PURL sans version ; elle pouvait fausser l'application des déclarations VEX, qui indiquent qu'un produit n'est pas affecté par une vulnérabilité.

Les équipes qui appliquent des déclarations OpenVEX au tri doivent installer cette version. Des SBOM décrivant des modèles d'IA pourraient interrompre une chaîne d'analyse automatisée avec une version plus ancienne.

Syft 1.56 : catalogage complet des archives

Syft 1.56 : publiée le 2 novembre 2026, cette version du générateur de SBOM d'Anchore catalogue entièrement le contenu des archives et exporte l'identifiant PURL de la source comme référence externe.

La version corrige aussi le hachage des fichiers, désormais calculé une fois par fichier, la détection des binaires envoy et istio, et des identifiants CPE erronés pour les paquets trouvés par le catalogueur Bitnami.

Les SBOM de livrables composés d'archives imbriquées peuvent gagner en exhaustivité. Un inventaire plus complet pourrait faire apparaître des composants, donc des vulnérabilités ou des licences, jusqu'ici invisibles.

EN BREF

cdxgen : depuis les versions 12.8.7 et 13.5, le générateur de SBOM corrige une faille critique de son mode serveur.

Dependency-Track 5.2.1 : depuis le 25 octobre 2026, cette version corrige un contrôle d'accès inopérant de la plateforme d'analyse de SBOM.

SÉCURITÉ DE LA CHAÎNE D'APPROVISIONNEMENT

Une faille du noyau Linux rejoint le catalogue des vulnérabilités exploitées ; une extension d'éditeur de code a été piégée sur la place de marché de Cursor ; Chrome annonce le retrait d'une racine d'eMudhra.

Noyau Linux : la faille « Fragnesia » activement exploitée

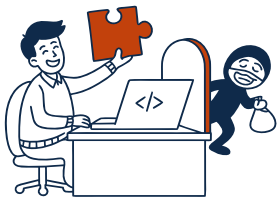
Noyau Linux : le 28 octobre 2026, la CISA a inscrit dans son catalogue des vulnérabilités activement exploitées une élévation de privilèges locale, « Fragnesia », divulguée en mai ; selon la CISA, elle peut être enchaînée avec les failles de PHP pour exécuter des commandes en administrateur.

La faille, liée au traitement des paquets chiffrés ESP transportés sur TCP, permet à un utilisateur local d'élever ses privilèges. Elle appartient à la famille « Dirty Frag ».

C'est l'enchaînement qui la rend dangereuse : avec les failles de PHP, un attaquant implante une porte dérobée web puis prend la main sur le système. Pour la CISA, elle touche un composant open source susceptible d'équiper différents produits.

Le fabricant doit comparer les noyaux livrés, y compris ceux des paquets de support des fournisseurs de cartes, aux correctifs disponibles, et apprécier la déclaration au titre du CRA pour les produits concernés. Un équipement doté d'une interface web en PHP sur un noyau vulnérable pourrait être pris en main à distance.

Une extension d'éditeur de code piégée sur la place de marché de Cursor



Extension piégée : le 29 octobre 2026, une version modifiée de façon malveillante de l'extension Claude Code pour VS Code a été servie pendant environ onze heures par la place de marché de Cursor ; elle installait une porte dérobée SSH persistante, qui survit à la désinstallation.

Selon Cursor, ces versions n'ont pas été développées par Anthropic, éditeur de l'extension. Cursor dit avoir contrôlé les accès, constaté qu'aucune autre extension n'avait été modifiée, renouvelé ses clés et reconstruit sa place de marché. Selon Help Net Security, 5 000 utilisateurs au plus ont été touchés ; Cursor prévoit de les contacter.

La porte dérobée, détectée par Phorion, vise macOS, Linux et Windows. Un poste touché doit être nettoyé au-delà de la simple désinstallation, et les accès SSH qui en partent vérifiés.

Sur un poste qui construit ou signe du logiciel livré, une telle porte dérobée pourrait servir à altérer les produits ou à dérober des clés.

eMudhra : Chrome annonce le retrait d'une racine de son magasin de certificats

Mise à jour, eMudhra : Google a annoncé le retrait, prévu le 27 octobre 2026, d'une racine d'eMudhra du magasin de certificats de Chrome, après la compromission d'autorités intermédiaires ; des certificats légitimes cesseront de fonctionner.

Google a annoncé ce retrait le 20 octobre. Certains certificats légitimes rattachés à cette racine cesseront d'être acceptés par Chrome sur tous les appareils qui s'appuient sur son magasin.

Node.js a mis à jour le magasin de certificats intégré à ses versions 26, 24 et 22.

Un produit qui embarque son propre magasin de certificats, ou un environnement Node.js, doit être mis à jour par son fabricant. Un équipement qui présente un certificat rattaché à cette racine pourrait devenir inaccessible depuis certains navigateurs.

EN BREF

LiteLLM : le 21 octobre 2026, une version 1.107 piégée de cette bibliothèque Python a été publiée sur PyPI pendant environ deux heures.

GhostAction : la campagne de vol d'identifiants vise plus de 30 000 dépôts de 3 000 utilisateurs et organisations, après la compromission d'environ 1 900 comptes GitHub.

COMMERCE INTERNATIONAL

Exportations et sanctions

La règle des affiliés du BIS doit revenir le 10 novembre ; l'OFAC sanctionne Extreme Networks et des réseaux de faux informaticiens nord-coréens ; l'Inde assouplit ses autorisations SCOMET.

Règle des affiliés du BIS : réimposition toujours prévue le 10 novembre

Mise à jour, règle des affiliés du BIS : à une semaine de sa réimposition prévue le 10 novembre 2026, aucune prolongation n'est publiée ; selon le cabinet Pillsbury, une prolongation de deux mois, jusqu'au 10 janvier 2027, a été annoncée sans texte du BIS.

Suspendue depuis le 10 novembre 2025, la règle étend les restrictions de l'Entity List aux entités détenues à 50 % ou plus par des entités inscrites.

Tant qu'aucun texte n'est publié, la date du 10 novembre reste celle de la règle en vigueur. Un industriel dont un produit ou une mise à jour relève de l'EAR doit filtrer ses clients selon leur chaîne de détention.

OFAC : transaction avec Extreme Networks pour des livraisons à une entité bloquée

OFAC, Extreme Networks : le 27 octobre 2026, l'équipementier réseau américain a accepté de payer 1 529 685 dollars pour avoir exporté à neuf reprises, entre 2018 et 2022, du matériel et du logiciel vers une entité bloquée, détenue majoritairement par le groupe russe Almaz-Antey.



Selon l'OFAC, MMZA était bloquée parce que détenue majoritairement par Almaz-Antey, inscrite sur sa liste de sanctions.

L'autorité souligne l'importance de la diligence en matière de sanctions avant l'acquisition d'une entreprise ou de ses actifs.

Le logiciel est traité comme le matériel : les portails de téléchargement et de mise à jour doivent filtrer leurs comptes clients. Une acquisition pourrait faire hériter l'acquéreur de relations avec des entités bloquées.

OFAC : sanctions contre des facilitateurs des faux informaticiens nord-coréens

OFAC, Corée du Nord : le 28 octobre 2026, l'OFAC a sanctionné dix personnes et une entité pour leur rôle dans les réseaux de faux informaticiens nord-coréens, qui se font embaucher sous de fausses identités par des entreprises des États-Unis et de pays alliés.

Selon le Trésor américain, la Corée du Nord continue de recourir à des documents frauduleux, à des identités volées et à des personnages fabriqués pour placer ses informaticiens dans des entreprises légitimes.

Ces travailleurs à distance financent le régime ; ils peuvent aussi obtenir un accès aux systèmes et au code de leurs employeurs. Le filtrage au titre des sanctions doit donc s'étendre aux sous-traitants du développement logiciel et à leurs intervenants.

Inde : les autorisations générales SCOMET étendues à de nouveaux exportateurs

Inde, SCOMET : selon l'avis public n° 37/2026-27 de la DGFT du 2 novembre 2026, d'application immédiate, les autorisations générales SCOMET, dont celle des articles de sécurité de l'information, sont étendues aux exportateurs titulaires d'un statut quatre ou cinq étoiles.

La DGFT, direction indienne du commerce extérieur, modifie le chapitre 10 de son manuel des procédures. Les facilités concernées couvrent aussi le stock et la vente, la réexportation après réparation en Inde et les télécommunications. La validité de l'autorisation de réexportation après réparation passe d'un à trois ans.

Les partenaires indiens titulaires de ces statuts peuvent désormais réexporter plus simplement des articles réparés ou de sécurité de l'information.

EN BREF

Royaume-Uni, listes de contrôle : la mise à jour des contrôles sur les biens, logiciels et technologies militaires et *dual-use* devrait entrer en vigueur début décembre 2026.

Royaume-Uni, classement : le service CLC de l'ECJU, suspendu depuis le 12 octobre 2026, doit faire un point d'avancement avant la fin de l'année.

CMMC : la suspension de la phase 2, décidée le 13 juillet 2026, reste sans date de reprise ; NIST SP 800-171 et DFARS 252.204-7012 restent applicables.

FRANCE ET UE

NIS2, IA, défense

Les normes harmonisées de l'AI Act sont attendues pour février 2027 ; la Commission ouvre un deuxième appel SAFE ; la loi Résilience n'est toujours pas réinscrite.

AI Act : les normes harmonisées attendues pour février 2027

AI Act, normes harmonisées : selon un compte rendu publié le 28 octobre 2026 par le CEN-CENELEC, la demande de normalisation de la Commission a été révisée après le *Digital Omnibus on AI* et fixe à février 2027 l'échéance des normes harmonisées.

L'article, signé par la Confédération européenne des syndicats, rend compte de la 15e réunion plénière du comité technique JTC 21 sur l'intelligence artificielle, tenue du 6 au 9 octobre à Winterthur. Plusieurs normes seraient en voie d'achèvement à cette date ; la Commission a rappelé le besoin de normes de qualité.

Les règles sur les systèmes d'IA à haut risque de l'annexe III ont été reportées au 2 décembre 2027. Hors l'EN 18286 sur le système de management de la qualité, aucune norme harmonisée ne donne encore de présomption de conformité. Des normes publiées en février 2027 laisseraient une dizaine de mois aux produits civils ou à double usage concernés.

SAFE : un deuxième appel de 21,3 milliards d'euros

SAFE : le 29 octobre 2026, la Commission a invité les États membres à un deuxième appel de 21,3 milliards d'euros de prêts pour l'achat de produits de défense, ouvert à tous les États membres.

La Commission demande de donner la priorité aux besoins urgents des forces ukrainiennes et européennes : défense aérienne et antimissile, drones et lutte anti-drones, munitions et missiles. Selon elle, les accords de prêt des 19 États participants ont été approuvés et 16 sont signés ; près de 13,5 milliards d'euros ont été versés à 11 États.

L'appel s'adresse aux États membres et oriente leurs achats vers ces besoins prioritaires. Des commandes financées pourraient en découler, avec les exigences de conformité logicielle des contrats qui les accompagnent.

EN BREF

Loi Résilience : la conférence des présidents du 27 octobre 2026 n'a pas réinscrit le projet de loi transposant NIS2 ; la suivante se réunit le 3 novembre.

Omnibus défense : la directive sur les transferts intra-UE de produits de défense a été adoptée par le Conseil le 9 octobre 2026 et signée le 21 octobre.

Responsabilité du fait des produits : la directive (UE) 2024/2853, qui couvre le logiciel, doit être transposée au plus tard le 9 décembre 2026.

LICENCES OPEN SOURCE ET LOGICIELS EMBARQUÉS

L'outil REUSE, qui vérifie les avis de licence, rétablit le téléchargement des textes de licence ; aucune décision ni aucun relicenciement n'a été relevé dans les sources consultées.

REUSE 6.3 : la commande de téléchargement des licences rétablie

REUSE 6.3 : publiée le 30 octobre 2026, cette version de l'outil de la FSFE qui vérifie les avis de licence fichier par fichier rétablit la commande de téléchargement des textes de licence, hors service sans cette mise à jour, l'adresse de la liste SPDX ayant changé.



L'adresse d'où les textes de licence sont téléchargés est inscrite dans le code de l'outil ; elle a changé. Selon les notes de version, la commande ne fonctionne pas correctement sans cette version ou un correctif.

REUSE fait porter à chaque fichier son avis de droit d'auteur et sa licence, et range les textes de licence dans un dossier dédié.

Les chaînes d'intégration qui téléchargent les textes de licence doivent être mises à jour. Des textes manquants ou erronés pourraient sinon se retrouver dans les avis livrés avec un produit.

EN BREF

Oracle JDK 21 : depuis la version 21.0.13 du 20 octobre 2026, les mises à jour sont proposées sous licence OTN, qui ne permet pas la redistribution.

GPL, SFC contre Vizio : le procès est indiqué par la SFC pour fin 2026 ; aucun verdict n'a été relevé dans les sources consultées.

GLOSSAIRE

Sigles et termes cités

AI Act Règlement européen 2024/1689

Akrites SIRT Équipe de réponse aux incidents de sécurité devenue autorité de numérotation CVE

Almaz-Antey Groupe industriel russe de défense antiaérienne

Anchore Éditeur d'une plateforme de sécurité de la chaîne logicielle fondée sur les SBOM

BIS Bureau of Industry and Security

Brotli Bibliothèque open source de compression de données créée par Google

cdxgen Outil open source du projet CycloneDX

CEN-CENELEC Comités européens de normalisation (CEN) et de normalisation électrotechnique (CENELEC)

CISA Agence américaine de cybersécurité et de sécurité des infrastructures

CLC Control List Classification

CMMC Cybersecurity Maturity Model Certification

CNA CVE Numbering Authority

CRA Cyber Resilience Act

Cursor Éditeur de code dérivé de VS Code

CVE Common Vulnerabilities and Exposures

CycloneDX Standard de nomenclature des composants (BOM)

DFARS 252.204-7012 Clause du règlement d'acquisition de la Défense américaine imposant la protection des informations non classifiées et la déclaration des incidents cyber

DGFT Directorate General of Foreign Trade

Digital Omnibus Ensemble de propositions de la Commission de novembre 2025 visant à simplifier les règles numériques de l'UE

Directive (UE) 2024/2853 Directive sur la responsabilité du fait des produits défectueux

EAR Export Administration Regulations

ECJU Export Control Joint Unit

eMudhra Autorité de certification indienne

EN Norme européenne

ENISA Agence de l'Union européenne pour la cybersécurité

ETSI Institut européen des normes de télécommunications

FSFE Free Software Foundation Europe

GitHub Plateforme collaborative de développement logiciel

GPL GNU General Public License

Grype Scanneur open source de vulnérabilités

ITAR International Traffic in Arms Regulations

JDK Java Development Kit

LiteLLM Bibliothèque Python open source et passerelle

NIS2 Directive européenne fixant des exigences unifiées de cybersécurité et de notification d'incidents

NIST Institut national américain des normes et de la technologie

NIST SP 800-171 Publication du NIST qui fixe les exigences de sécurité

OFAC Office of Foreign Assets Control : service du Trésor américain qui administre et fait appliquer les sanctions économiques.

OpenSSF Communauté de développeurs et d'ingénieurs sécurité

OpenVEX Format open source de document VEX

OTN Oracle Technology Network License Agreement for Java SE

OWASP Dependency-Track Plateforme open source d'inventaire de composants et de détection de vulnérabilités à partir de SBOM

PHP Langage de programmation très utilisé

PURL Package URL

PyPI Python Package Index

REUSE Spécification et outil de la FSFE

SAFE Security Action for Europe

SBOM Software Bill of Materials

SCOMET Special Chemicals, Organisms, Materials, Equipment and Technologies

SFC Software Freedom Conservancy

SPDX System Package Data Exchange

SSH Secure Shell

Syft Générateur open source de SBOM d'Anchore

TS Spécification technique

VEX Vulnerability Exploitability eXchange

Vizio Fabricant américain de téléviseurs connectés

VS Code Visual Studio Code

AGENDA

Dates à surveiller

10 NOV. — EXPORT ÉTATS-UNIS
Réimposition automatique de la règle des affiliés du BIS, sauf prolongation

NOV. 2026 — EXPORT UE
Règlement délégué adopté le 14 septembre 2026 ; publication au JO après deux mois d'examen du Parlement européen et du Conseil, sauf objection

30 NOV. — EXPORT ÉTATS-UNIS
Projet publié le 1er octobre 2026 : retrait de certains articles de la liste, définitions révisées, nouvelle exemption de licence

DÉC. 2026 — EXPORT ROYAUME-UNI
Mise à jour des listes militaire et dual-use (biens, logiciels, technologies) annoncée par l'avis aux exportateurs 2026/24

9 DÉC. — RESPONSABILITÉ PRODUIT
Transposition de la directive (UE) 2024/2853, qui inclut le logiciel ; elle s'applique aux produits mis sur le marché à partir de cette date

DÉC. 2027 — AI ACT
Règles sur les systèmes d'IA à haut risque de l'annexe III, reportées à cette date par le règlement (UE) 2026/1744

DÉC. 2027 — CRA
Application complète du CRA ; selon l'ENISA, les gestionnaires de logiciels open source sont soumis à la déclaration à la même date

Software Compliance
Revue de presse hebdomadaire, N° 5 du 3 novembre 2026.
Rédigée par une intelligence artificielle (Claude Opus 5.5), peut comporter des erreurs : pensez à croiser vos sources.
Édition en ligne avec sources : revue.dejeun.es/2026-11-03
© 2026 Rodolphe Dejeunes, publié sous licence CC BY 4.0.